Merge Status Code

PROM06 TC15 – Hard-coded secret in variable default (INDEPENDENT) #84

Open abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc15`

Conversation 9 Commits 1 Checks 1 Files changed 1 +7

Reviewers

No reviews

Still in progress? Convert to draft

Assignees

No one—assign yourself

Labels

None yet

Projects

None yet

Milestone

No milestone

Development

Successfully merging this pull request may close these issues.

None yet

1 participant





abdulwaheed384 commented 3 hours ago Owner

PROM06 additional test case TC15 (Hard-coded secret in variable default), run under the INDEPENDENT workflow (post-PR #69). Ground truth was committed before the fixture: evidence/prom06/ground-truth/TC13-TC15_Ground_Truth.md on branch prom06-evidence. Research fixture only: do not merge, do not apply.

🤖 Generated with Claude Code

https://claude.ai/code/session_019GGG1f33Kz2g4dpPAJoY44

Generated by Claude Code

`PROM06 TC15: admin password variable` ··· Unverified ✓ `049f9c9`

github-actions Bot commented 3 hours ago

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 7 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.

github-actions Bot commented 3 hours ago

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_CLEAN
Findings: 0

No findings were reported.

github-actions Bot commented 3 hours ago

AI Security Review

Experiment condition: INDEPENDENT
Automated operational score: 70/100 — MEDIUM — APPROVE_WITH_COMMENTS
This tool is for demonstration purposes only.

Summary

The AI reviewer reported 1 confirmed actionable finding(s).

Findings

- **HIGH · SECURITY_VULNERABILITY · Hardcoded plaintext administrator password in Terraform variable default**
  - Category rationale: The Terraform variable 'admin_password' in tc15_variables.tf has a hardcoded plaintext default value 'Prom06-Lab-Passw0rd-2026'. This embeds a credential directly in source-controlled code, exposing it to all repository readers and persisting it in git history regardless of the file's 'Do not deploy' comment. A committed secret is a concrete, current security weakness independent of deployment intent.
  - Evidence: terraform/tc15_variables.tf: variable "admin_password" { description = "Administrator password for the research database." type = string default = "Prom06-Lab-Passw0rd-2026" }
  - Analysis: The file tc15_variables.tf declares a Terraform variable 'admin_password' with type string and a plaintext password set as the default value ('Prom06-Lab-Passw0rd-2026'). Hardcoding a credential as a default in a variable definition means it is committed to version control and readable by anyone with repository access. Even if the file is never applied, the credential is now part of the repository history and must be treated as compromised. The 'Do not deploy' comment does not prevent the secret from being exposed via the repository.
  - Impact: The administrator password is exposed in plaintext in version control. Any party with read access to this repository — including current and former collaborators, CI/CD systems, and anyone with access to git history after a future public disclosure — can read the credential. If this password is reused or deployed, it enables direct authentication to the research database without further attack steps.
  - Recommendation: Remove the hardcoded default value immediately. Rotate the exposed credential. Use a secrets management solution such as Azure Key Vault with a data source reference, a Terraform Cloud/Enterprise variable marked as sensitive, or an environment variable (TF_VAR_admin_password) with no default in code. The variable declaration should be: variable "admin_password" { description = "Administrator password for the research database." type = string sensitive = true } with the value supplied at plan/apply time from a secure store, never from a default in source code. Review git history and purge the credential using git filter-repo or equivalent if the repository is or may become accessible to untrusted parties.

Policy mappings

- **SEC-001** — No resource should be publicly exposed unless explicitly required and justified. (finding F-001)

Recommendation

Review and remediate the confirmed findings above.





github-actions Bot commented 3 hours ago

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 7 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.





github-actions Bot commented 3 hours ago

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_CLEAN
Findings: 0

No findings were reported.





github-actions Bot commented 3 hours ago

AI Security Review

Experiment condition: INDEPENDENT
Automated operational score: 70/100 — MEDIUM — APPROVE_WITH_COMMENTS
This tool is for demonstration purposes only.

Summary

The AI reviewer reported 1 confirmed actionable finding(s).

Findings

- **HIGH · SECURITY_VULNERABILITY · Hardcoded plaintext database password committed as a Terraform variable default**
  - Category rationale: The variable 'admin_password' in tc15_variables.tf has a plaintext hardcoded default value 'Prom06-Lab-Passw0rd-2026'. This default is committed to version control and will be recorded in Terraform state in plaintext. Any actor with read access to the repository or state backend can recover the credential without further privilege escalation.
  - Evidence: terraform/tc15_variables.tf — variable "admin_password" { default = "Prom06-Lab-Passw0rd-2026" }
  - Analysis: The file tc15_variables.tf declares a variable 'admin_password' with a hardcoded string default 'Prom06-Lab-Passw0rd-2026'. Terraform variable defaults are stored in source control and, when the variable is consumed by a resource, the resolved value is also written to Terraform state in plaintext. Even if the resource consuming this variable is not present in the supplied files, the default itself is exposed to all repository readers and to any system (CI runner, artifact store) that processes the Terraform directory. The file comment states 'Do not deploy', but the default value is still committed and readable.
  - Impact: The password is exposed to anyone with repository read access, CI/CD log access, or Terraform state access. If this credential is reused or if the fixture is accidentally applied, the database account it protects is immediately compromised without requiring any additional attack steps.
  - Recommendation: Remove the default value entirely so that Terraform requires the caller to supply the password explicitly (type = string, no default, sensitive = true). Source the value at apply-time from a secrets manager (e.g., Azure Key Vault via data source, or a Terraform Cloud/workspace variable marked sensitive). Mark the variable sensitive = true to suppress it from plan/apply output and reduce state exposure. Rotate the committed credential immediately if it has been or could be applied to any environment.

Policy mappings

- **SEC-001** — No resource should be publicly exposed unless explicitly required and justified. (finding F-001)

Recommendation

Review and remediate the confirmed findings above.





github-actions Bot commented 3 hours ago

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 7 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.





github-actions Bot commented 3 hours ago

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_CLEAN
Findings: 0

No findings were reported.





github-actions Bot commented 3 hours ago

AI Security Review

Experiment condition: INDEPENDENT
Automated operational score: 70/100 — MEDIUM — APPROVE_WITH_COMMENTS
This tool is for demonstration purposes only.

Summary

The AI reviewer reported 1 confirmed actionable finding(s).

Findings

- **HIGH · SECURITY_VULNERABILITY · Hardcoded plaintext password in Terraform variable default**
  - Category rationale: The variable 'admin_password' in tc15_variables.tf contains a hardcoded plaintext password as its default value ('Prom06-Lab-Passw0rd-2026'). This value is committed to source control, making it readable to any party with repository access. A default value in a Terraform variable is stored in the state file and version history regardless of whether the variable is overridden at runtime. This is a concrete, demonstrated weakness independent of the research or non-production context.
  - Evidence: terraform/tc15_variables.tf: variable "admin_password" { default = "Prom06-Lab-Passw0rd-2026" }
  - Analysis: The file tc15_variables.tf declares a variable 'admin_password' with a hardcoded default value of 'Prom06-Lab-Passw0rd-2026'. Any credential stored as a Terraform variable default is committed to version control in plaintext and will appear in the Terraform state file. This exposes the credential to all repository contributors, CI/CD pipeline logs, and anyone with access to the state backend, for the lifetime of the repository history.
  - Impact: The password is exposed in version control history and Terraform state. If this credential is used against any deployed resource (e.g., a database), it can be extracted by any party with repository read access or state backend access. Even if the variable is overridden at deploy time, the default value persists in git history and may be mistakenly used in non-production deployments.
  - Recommendation: Remove the default value entirely so that Terraform requires the caller to supply the password explicitly at plan/apply time. Source the secret from a secure store such as Azure Key Vault (via a data source), a CI/CD secret variable, or a secrets management tool. If the default has already been committed, rotate the credential and consider the previous value permanently compromised. Example: remove the 'default' attribute and retrieve the value with 'data "azurerm_key_vault_secret"' or pass it via a TF_VAR_ environment variable from the pipeline secrets store.

Policy mappings

- **SEC-001** — No resource should be publicly exposed unless explicitly required and justified. (finding F-001)

Recommendation

Review and remediate the confirmed findings above.

abdulwaheed384 added a commit that referenced this pull request 3 hours ago

`PROM06: AI quality scoring sheets; TC13–TC15 scans and PR comments` Unverified `ef17f33`

...

All checks have passed
2 successful checks

No conflicts with base branch
Merging can be performed automatically.

Merge pull request | You can also merge this with the command line. View command line instructions.

Still in progress? Convert to draft